Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Arquitectura Zero Trust y Marcos Corporativos

Ing. Roxana Quiroga Sollinger



Módulo 2: Arquitectura Zero Trust y Marcos Corporativos

FADENA

2.1 Arquitectura y gobierno Zero Trust

2.2 Microsoft Security Development Lifecycle

2.3 Seguridad en DevSecOps



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

Arquitectura y Gobierno Zero Trust



2.1 Arquitectura y Gobierno Zero Trust

FADENA

- Definiciones
- Modelo de Confianza Cero (Zero Trust - ZT)
- Gobierno Zero Trust (ZTG)
- Arquitectura Zero Trust (ZTA)
- Amenazas



FADENA

2.1 Arquitectura y Gobierno Zero Trust

Definiciones

Zero Trust (ZT)

Modelo de confianza cero (ZT) proporcia conceptos e ideas diseñados para miniminizar la incertidummbre en la aplicaciones de acceso precisas.

Arquitectura ZT (ZTA)

Plan de ciberseguridad de una empresa que utiliza ZT y abarca las relaciones entre components, la planificacion del flujo de trabajo y políticas de acceso.

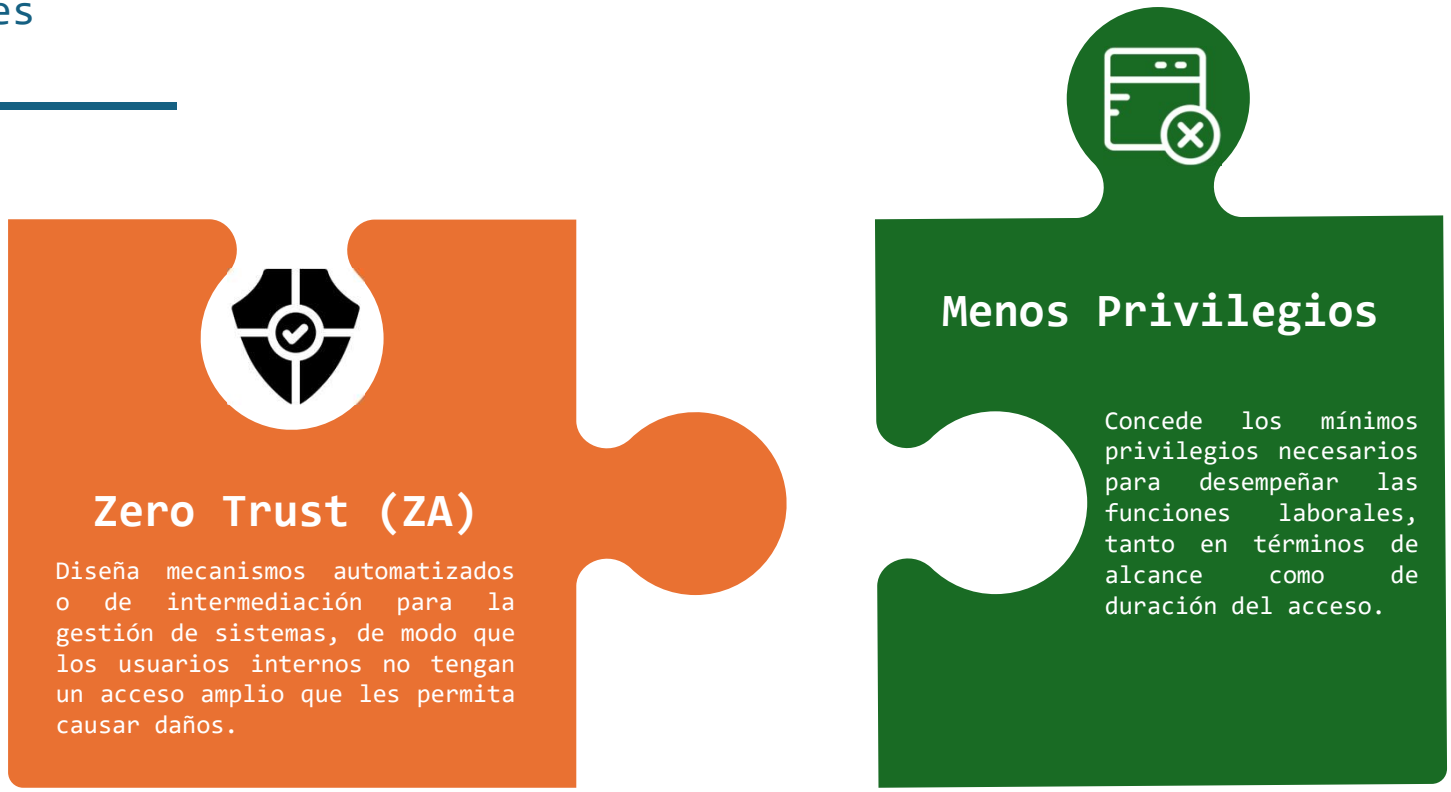
Gobierno ZT

Estrategia de aplicar el modelo de confianza zero a la gestion organizacional.



2.1 Arquitectura y Gobierno Zero Trust

Definiciones



2.1 Arquitectura y Gobierno Zero Trust

Definiciones

Perímetro de Seguridad

01 Un límite físico o lógico que se define para un sistema, dominio o enclave, dentro del cual se aplica una política de seguridad o arquitectura de seguridad particular.

02 El límite donde se aplican controles de seguridad para proteger los activos.

03 Si un dispositivo puede operar dentro de una red privada, luego utilizarse externamente con acceso directo a internet y posteriormente regresar a la red privada, no existe un perímetro de seguridad real.

2.1 Arquitectura y Gobierno Zero Trust

Zero Trust

El concepto de confianza cero implica que nada ni nadie dentro de la organización es automáticamente confiable



Microsegmentación

La microsegmentación consiste en dividir una red interna en numerosas subzonas.

2.1 Arquitectura y Gobierno Zero Trust

Zero Trust

Zona de no confianza

Pilares del Acceso

El sistema debe garantizar la autenticidad del sujeto y la validez de la solicitud

NIVEL DE CONFIANZA

PERMISIBILIDAD DEL RECURSO

DISPOSITIVO

Horario

Ubicación geográfica



Sanidad

Autorización

El PDP (Punto de Decisión de Políticas) y PEP (Punto de Aplicación de Políticas) emiten el juicio adecuado para otorgar acceso. Evalúan la validez estricta de la solicitud antes de abrir cualquier canal hacia el recurso.

Autenticación contínua

El sistema debe verificar y garantizar la autenticidad del sujeto para la solicitud específica que está realizando. No basta con una validación previa; se valida la identidad de forma activa en el contexto de la acción actual.

2.1 Arquitectura y Gobierno Zero Trust

Zero Trust

Zona de confianza implícita

Filtro de Seguridad

Todos las entidades pasan obligatoriamente por el punto de control de seguridad (PDP/PEP). Una vez cruzado este filtro actúa como la zona de confianza implícita.

LÍMITE DE APLICACIÓN DE POLÍTICAS

REDUCCIÓN DE ZONA

Autorización

Una vez que el tráfico supera el punto de evaluación de políticas (PEP), las entidades dentro de dicha zona interactúan sin requerir validaciones adicionales en cada paso.

Nivel mínimo de confianza

Representa un área donde todas las entidades internas disfrutan de un nivel de confianza al menos igual al del último punto de control PDP/PEP (Policy Decision Point / Policy Enforcement Point).

FADENA

2.1 Arquitectura y Gobierno Zero Trust

Gobierno ZT (ZTG)

Principios de implementación de Arquitectura Zero Trust (ZTA)



Recursos

Todas las fuentes de datos y los servicios informáticos se consideran recursos.

Comunicaciones Seguras

Todas las comunicaciones están protegidas, independientemente de su ubicación en la red.

Acceso

El acceso a los recursos empresariales individuales se concede por sesión y su confianza se evalúa antes.

Políticas dinámicas

El acceso a los recursos se determina mediante una política dinámica, como la identidad del cliente, la aplicación, servicio y el activo solicitante

Monitoreo y Seguimiento

La empresa supervisa y mide la integridad y la seguridad de todos sus activos, tanto propios como asociados. Ningún activo es inherentemente confiable. La empresa debe establecer un CDM.

Autenticación y Autorización

La autenticación y autorización de todos los recursos son dinámicas y se aplican rigurosamente antes de permitir el acceso.

Información sobre activos

La empresa recopila la mayor cantidad de información posible sobre el estado actual de sus activos, infraestructura de red y comunicaciones

FADENA

2.1 Arquitectura y Gobierno Zero Trust

Gobierno ZT (ZTG)

Principios de implementación de una red Zero Trust



Red Privada

La red privada de la empresa no se considera una zona de confianza implícita.

Dispositivos

Los dispositivos de la red pueden no ser propiedad de la empresa ni estar configurados por ella.

Confiabilidad

Ningún recurso es inherentemente confiable.

Alcance de la Infraestructura

No todos los recursos empresariales se encuentran en infraestructura propiedad de la empresa.

Activos Remotos

Los sujetos y activos empresariales remotos no pueden confiar plenamente en su conexión de red local.

Política y Seguridad

Los activos y flujos de trabajo que se mueven entre infraestructuras empresariales y no empresariales deben tener una política y un nivel de seguridad coherentes.